Podstawowe pojęcia bezpieczeństwa informacji

Materiał edukacyjny do demonstracji. Ogólne zagadnienia bezpieczeństwa informacji.

Zakres materiału

Uogólnione opracowanie edukacyjne pojęć używanych w zarządzaniu bezpieczeństwem informacji. Nie jest tekstem normy ISO/IEC 27001 ani opisem wdrożenia w konkretnej organizacji.

Poufność

Informacja jest dostępna wyłącznie dla uprawnionych osób, podmiotów lub procesów. Przekazanie informacji zewnętrznej usłudze wymaga uwzględnienia tego, kto uzyska do niej dostęp i w jakim celu.

Integralność

Informacje i zasoby zachowują dokładność i kompletność. Ochrona integralności obejmuje zapobieganie nieuprawnionym zmianom.

Dostępność

Uprawniony podmiot może skorzystać z informacji lub usługi wtedy, gdy jej potrzebuje.

Aktywo i zagrożenie

Aktywem jest to, co ma wartość dla organizacji, na przykład informacja, proces, oprogramowanie lub urządzenie. Zagrożenie jest potencjalną przyczyną zdarzenia, które może wywołać szkodę.

Ryzyko

Ryzyko opisuje wpływ niepewności na cele. Szacowanie ryzyka obejmuje jego identyfikację, analizę i ocenę. Ryzyko rezydualne pozostaje po zastosowaniu wybranego postępowania z ryzykiem.

Incydent

Incydent bezpieczeństwa to niepożądane zdarzenie lub seria zdarzeń, które zagrażają bezpieczeństwu informacji albo zakłócają działalność.

Ciągłość działania

Ciągłość działania oznacza zdolność do dostarczania usług podczas zakłócenia w przyjętych ramach. RTO określa docelowy czas wznowienia działania. RPO określa punkt w czasie, do którego należy odtworzyć dane.

Zgodność

Zgodność oznacza spełnienie określonego wymagania. Ocena wymaga wskazania konkretnego wymagania i dowodu jego spełnienia. Samo podobieństwo sformułowań w dokumentach nie przesądza o zgodności.